MacZine

THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 046 · SEPTEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

CASE IN POINT · SUPPLY CHAIN

Subcontractor Cybersecurity: Your Sub's SPRS Score Is a Claim

Primes cannot see a sub's score in SPRS. Subcontractor cybersecurity requirements get verified with evidence - here is what to ask for.

BY **PATRICK CARUSO** READING TIME · 7 MIN SUPPLY-CHAIN · SPRS · DFARS · SUBCONTRACTING · C-SCRM

A prime contractor about to award a subcontract under a DoD program carrying DFARS 252.204-7012 is required to confirm something it has no way to look up. The clause next door, 252.204-7020, forbids the award unless the subcontractor has completed at least a Basic NIST SP 800-171 DoD Assessment within the last three years, and the database where that assessment lives will not show the prime a single digit of it. Subcontractor cybersecurity requirements, in other words, are verified the old-fashioned way: by asking, and by knowing which answers are worth believing.

The plain answer to what a prime can see is nothing. When DoD finalized its CMMC acquisition rule in September 2025, respondents asked for a way to query supplier status, and the Department's reply was blunt: contractors can access only their own records, no electronic tool shares a sub's information with its prime, and primes are expected to verify suppliers the way they verify any other flowdown. What DoD points to instead is the sub printing or screenshotting its own SPRS record and choosing to share it. A screenshot proves a score was posted. It does not prove the score is true, and 7020 itself says as much: a Basic Assessment carries a confidence level of "Low" because the contractor generated it.

Whether the flowdown still binds during the CMMC pause is a separate question, answered in an earlier issue; the 7012 and 7020 obligations never paused. This piece is about the method, and it is easiest to see applied. Consider a hypothetical mid-tier prime vetting three suppliers for the same program, each of whom has just told the prime, in effect, "we're fine."

FIELD COPY
ISSUE Nº 046
SUPPLY CHAIN

3

YEARS - THE OLDEST A SUBCONTRACTOR'S NIST SP 800-171 DOD ASSESSMENT CAN BE UNDER DFARS 252.204-7020(G)

0

SUBCONTRACTOR SCORES A PRIME CAN LOOK UP IN SPRS - CONTRACTORS SEE ONLY THEIR OWN RECORDS

Low

THE CONFIDENCE LEVEL DFARS 252.204-7020 ASSIGNS TO A BASIC ASSESSMENT, BECAUSE IT IS SELF-GENERATED

The perfect score with an expiration date

Supplier A sends a clean SPRS screenshot: 110 of 110, Basic Assessment, dated September 2023. On paper it is the strongest of the three. In practice it may be the only one the prime is flatly barred from awarding, because on a subcontract signed this October that assessment is past the three-year line in 7020(g)(2). The sub can fix that cheaply with a fresh Basic Assessment; the prime cannot waive it.

The date is only the first problem. A score of 110 means every one of the 110 requirements was implemented on the day of the assessment, with nothing left on a plan of action, and three years is a long time for a network to hold still. So the supplier SPRS score verification that matters starts with scope. Each submission names the CAGE codes covered by each system security plan. If the CAGE code performing the subcontract is not on that list, the 110 describes some other system. Ask for the SSP's current version date, too: under the DoD Assessment Methodology, 3.12.4 carries no point value because without a current plan no score can be submitted at all. A perfect score behind a plan nobody has touched since 2023 is a number without a document underneath it. How that 110 is built is its own subject; a prime should read a perfect self-score as the claim most in need of checking.

A posted score is a representation the supplier made to the government. It becomes evidence for the prime only when the supplier can show the work behind it.

◆ WHAT A BASIC ASSESSMENT SUBMISSION CARRIES

Under DFARS 252.204-7020(d), a sub posting a Basic Assessment sends the NIST SP 800-171 version, who performed it, the CAGE codes each system security plan covers, the completion date, the summary score, and the date it expects to reach 110. Ask for that same record. It is short, the sub already has it, and every field answers a verification question.

The honest 72

Supplier B posts 72, dated this spring, with a plan of action behind it. Thirty-eight points are missing, and a procurement team sorting by score would put this supplier last. A prime doing the work may put it first.

The difference is that a 72 with a dated plan is legible. The sub's submission already includes the date it expects to reach 110, drawn from its POA&M, so the prime's request is concrete: send the open line items, their weights, their owners, and their dates. If the missing points are a string of one-point documentation gaps with named owners, the supplier is a program in progress. If they include 3.6.1, the five-point requirement for an operational incident-handling capability, the prime has a sharper problem, because 7012 obliges every covered sub to report cyber incidents to DoD itself and, under paragraph (m), pass the incident report number up the chain as soon as practicable. Reporting through DIBNet requires a DoD-approved medium assurance certificate, which 7012(c) places on the subcontractor as squarely as on the prime. Ask whether the sub holds one today, and who in the company does. What a POA&M can defer is settled elsewhere; the prime's job is to confirm the plan is real.

Two more questions round out Supplier B's file. Where does its CUI actually live, and if a cloud provider stores it, does that provider meet the FedRAMP Moderate equivalency 7012 requires? And has the sub filed any request to vary from an 800-171 requirement? 7012(m) obliges a sub to tell its prime when it does. A supplier that answers all of this in a week says more about its program than any score could.

The shop that says it holds no CUI

Supplier C is a precision machine shop with no SPRS record at all. Its owner says the shop does not handle CUI. That may be true, but it is not the owner's call alone.

7012(m)(1) puts the determination on the prime: before flowing the clause down, the contractor decides whether the information the sub needs to perform retains its identity as covered defense information. If the job requires machining to a CUI-marked drawing, the shop handles CUI the moment the drawing arrives, whatever its owner believes. That leaves the prime two honest options. It can engineer the package so the shop receives only what it needs and nothing controlled, and document that decision. Or it can flow 7012 and 7020 in full and hold both the award and the drawings until the shop posts a current assessment. DoD's rule commentary is explicit that primes are not to pass CUI to subcontractors that have not indicated they meet the CMMC level the information requires. What the prime cannot do is accept "we don't handle CUI" as the whole record.

Tiering subcontractor cybersecurity requirements by exposure, not spend

The shop may be the smallest purchase order and the highest exposure in the program, which is why supply chain risk management for defense contractors sorts suppliers by what they hold, not what they cost. A workable tiering starts with one question per supplier: will it store, process, or transmit CUI, or could it reach systems that do? Those that will get the full evidence request - the submission record, SSP date and scope, open POA&M lines, cloud posture, and incident-reporting readiness - before any controlled data moves. Those that won't get a documented determination of why not, revisited when the statement of work changes.

The subcontract should carry that discipline forward. Beyond flowing 7012 without alteration and 7020 in substance, as both clauses require, the DFARS 252.204-7020 flowdown can be paired with terms the prime writes itself: delivery of the SPRS record at award and after every re-posting, prompt notice when the posted score or the SSP's scope changes, the right to request POA&M status, and a condition that no CUI is released until verification is complete. MacTech's supply chain practice manages this kind of sub-tier registry for primes and offers a shared CUI enclave for critical suppliers.

The direction of travel is visible in NIST SP 800-171 Revision 3, though DoD contracts remain pinned to Revision 2, the only revision SPRS scores. Rev 2 has no supply chain family. Rev 3 adds one: 03.17 asks for a supply chain risk management plan, for acquisition strategies and contract tools that identify and mitigate supply chain risk, and for a process to find and address weaknesses in supply chain elements. None of that is a scored obligation today. It does closely describe the C-SCRM file a careful prime should already keep on Suppliers A, B, and C.

Run the method and the prime's order of award inverts the procurement spreadsheet. Supplier B goes first, on the strength of a plan it can show. Supplier C proceeds only after the prime decides, in writing, what the shop will receive. Supplier A, with the best number of the three, waits until it posts a current assessment

and names the system it covers. A prime that wants help building that file before its next award can start at /readiness. ◆

MORE ISSUES
mactechsolutionsllc.com/maczine
new field copies with every merge

WORK WITH US
CMMC readiness · CUI enclaves · RMF
mactechsolutionsllc.com/contact

MACZINE
Written, reviewed and versioned in the open.
Published from Git, reviewed like code.